AlbertWesker: Gələcək Siyasəti

Mövcud FastAPI əsaslı təhlükəsizlik skanerindən daxili şəbəkə nəzarəti və davamlı uyğunluq üçün mərhələli transformasiya təklifi

Made with GAMMA

Problem və Biznes Konteksti

İnternet Yüzə Çevrilmiş Risklər

Mövcud sistem internet-facing infrastruktur üçün non-intrusive xarici yoxlamalar təmin edir. HTTP başlıqları, TLS sertifikatları, port açılışları və AWS konfiqurasiyaları üçün avtomatlaşdırılmış skanlar

Daxili Şəbəkə Boşluğu

LAN cihaz inventarı, agent-əsaslı endpoint yoxlaması, switch/AP telemetriyası və NAC inteqrasiyası hazırda built-in deyil. Bu məhdudiyyət bank və korporativ daxili nəzarət üçün əlavə arxitektura tələb edir

Icraçı Nəticə: Xarici müşahidə qabiliyyətini daxili şəbəkə nəzarəti ilə birləşdirərək risk nəzarət kontinuumu yaradılması tələb olunur

Made with GAMMA

Mövcud Platforma Arxitekturası

Web İnterfeys (FastAPI)

JWT autentifikasiyası, RBAC, admin/user rolləri və tarixçə idarəetməsi ilə REST API

Skan Mühərriki

HTTP security headers, TLS sertifikat yoxlamaları, port scanning və DNS resolution

AWS Heuristikası

Region, service və permission-specific yoxlamalar üçün təcrid olunmuş modul

PDF Hesabat

Audit-ə uyğun sənədləşmə, compliance mapping və evidence capture

Biznes Dəyəri: Avtomatlaşdırılmış yoxlamalar vaxt sərfi 90% azaldır və təkrarlanan audit hazırlıq xərclərini aradan qaldırır

Made with GAMMA

Texniki Analiz: Confidence və Risk Skorlama

Confidence Modeli

- **High:** Müstəqil təsdiq olunmuş yoxlamalar
- **Medium:** Heuristic inference ilə yoxlamalar
- **Low:** Ehtimal yoxlamaları
- **Manual Review:** Dəqiqlik üçün insan təsdiqi tələb olunur

Risk Skorlama

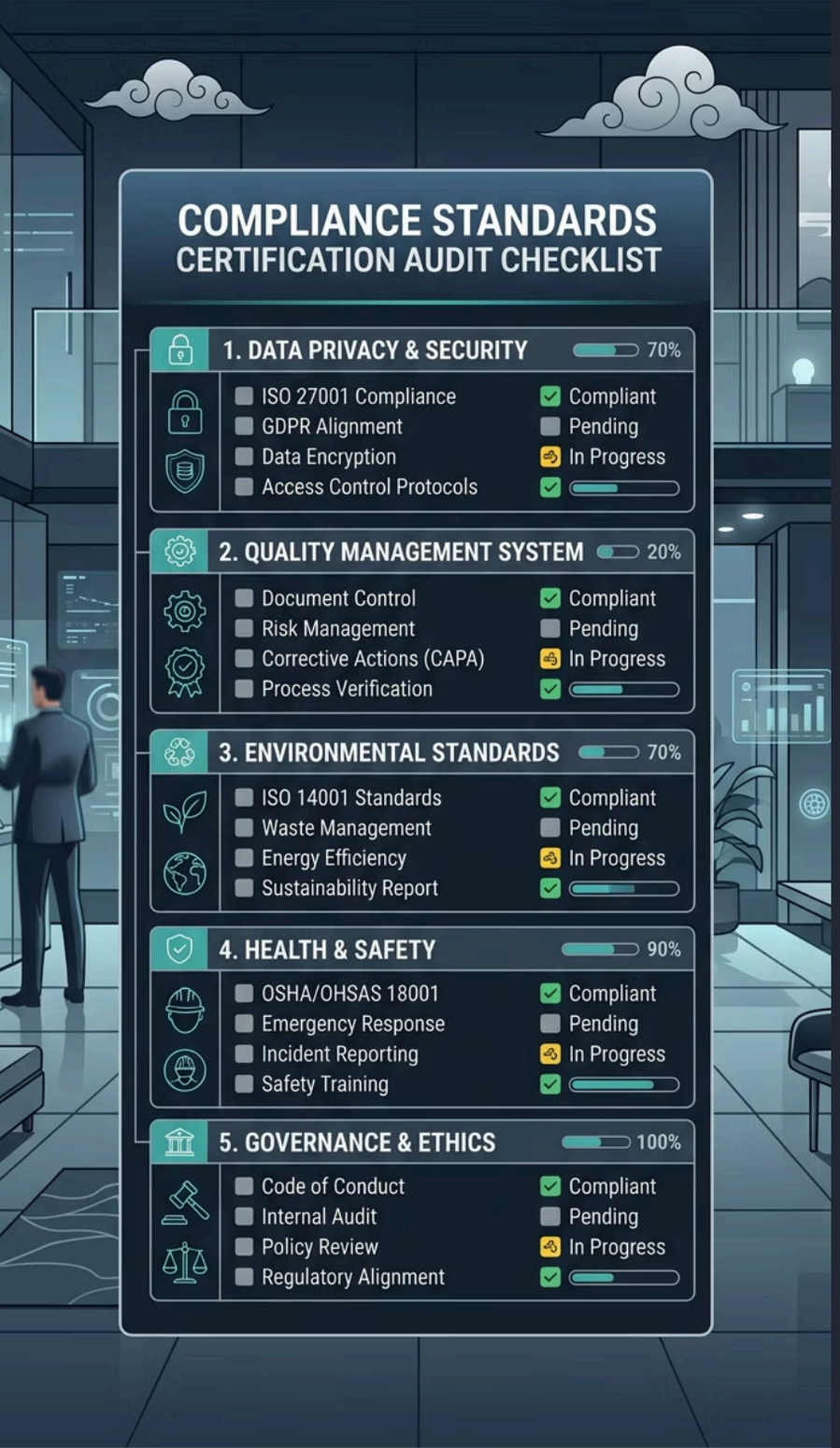
AWS və non-AWS yoxlamaları confidence multiplier, priority P1-P4 və risk normalizasiyası ilə skorlanır

Security Hardening

JWT risk nəzarəti, cookie hardening və SSRF target validation ilə 50+ security kontrolü tətbiq olunur

Biznes Dəyəri: Risk skorlama qərar keyfiyyətini artırır və resursların ən kritik problemlərə yönəldilməsini təmin edir

Made with GAMMA



Compliance Mapping və Audit Dəyəri

ISO 27001

Əsas məlumat təhlükəsizliyi tələblərinə uyğunluq. Control A.12, A.13 və A.14-in əhatə olunması

NIST SP 800-53

Əməliyyat və texniki təhlükəsizlik kontrolleri. SC-7, SC-12 və SI-2 nəzarət məqamlarının xəritələşdirilməsi

SOC 2

Sistem təhlükəsizliyi və məlumat müdafiəsi. Trust Services Criteria-ə uyğun evidence capture

Mapping strength, evidence type, confidence və manual review bayraqları ilə tam audit trail təmin olunur

Biznes Dəyəri: Audit hazırlıq müddəti 70% qısalır və evidence capture avtomatlaşdırılır

Made with GAMMA

Texniki Ziddiyyətlər və Borc

Code Truth Prioriteti

Kod fayllarından testlərə, sonrakı hesabat markdownlarına doğru mənbə prioriteti tətbiq olunur

Əsas Ziddiyyətlər

- **Assumption:** AWS IAM policy analysis tam RBAC audit təmin edir (testlərdə məhdud coverage)
- **Assumption:** Port scanning tam network inventory yaradır (agentless yoxlama ilə məhdudiyyət)
- **Assumption:** TLS certificate validation tam certificate transparency təmin edir

Texniki Borc

- Agentless LAN yoxlaması üçün əlavə modullar
- Switch/router konfiq drift detection
- Continuous compliance monitoring
- Real-time alerting və SIEM inteqrasiyası

Icraçı Nəticə: Ziddiyyətlərin təyin olunması roadmap planlaşdırması üçün prioritet təyin edir

Made with GAMMA

Gələcək Hədəf: Daxili Server Deployment

1 — **DMZ Variantı**

External-facing skanlar üçün reverse proxy, TLS termination və secret management ilə təcrid

2 — **Internal Segment**

LAN və Wi-Fi üzərindən cihazların şəbəkə daxili skanı üçün agentless yoxlama

3 — **Collector/Agent Model**

Endpoint visibility, vulnerability scan və config baseline üçün agent-əsaslı mexanizm

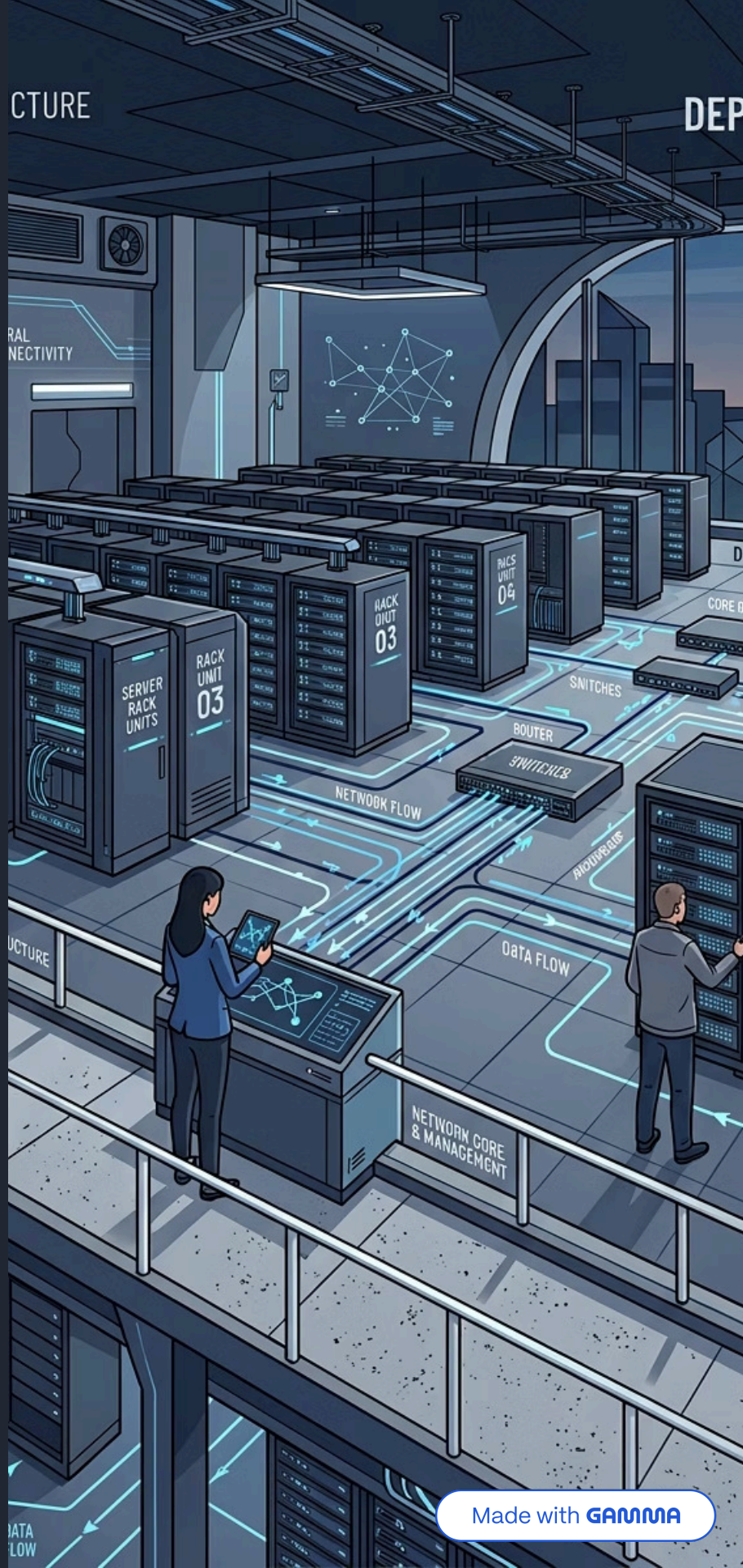
Şəbəkə Səviyyəsi

Asset inventory, segmentasiya yoxlaması, NAC və 802.1X uyğunluğu, switch/router/firewall konfiq drift nəzarəti

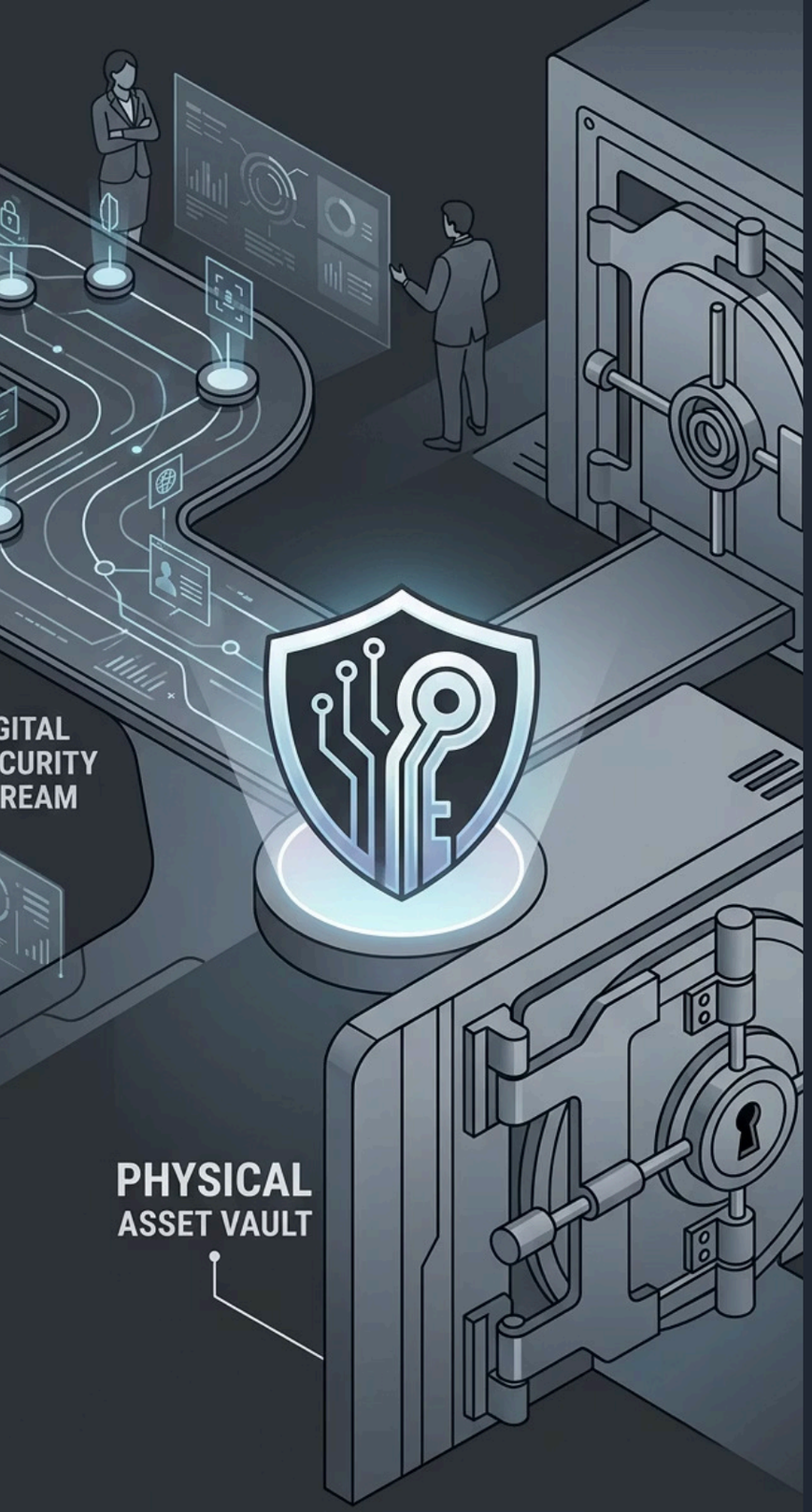
Cihaz Səviyyəsi

Server, endpoint, printer, IoT üçün profil əsaslı yoxlamalar və vulnerability scan + config baseline

Biznes Dəyəri: Daxili deploy agentless LAN/Wi-Fi yoxlaması ilə daxili şəbəkə risklərinin 30 gün ərzində aşkar edilməsini təmin edir



Made with GAMMA



İki Yol Xəritəsi: Şirkətlər və Banklar

Korporativ Şirkətlər Paketi

Standart Baseline:

- ISO 27001 və SOC 2 praktik baseline
- LAN/Wi-Fi cihaz inventarı
- HTTP/TLS/Port yoxlamaları
- Əsas network device konfiq drift nəzarəti
- Qoşulma əsaslı asset discovery

Target Segment: Middling security risk olan orta böyüklikdə korporativ şəbəkələr

Bank/Maliyyə Paketi

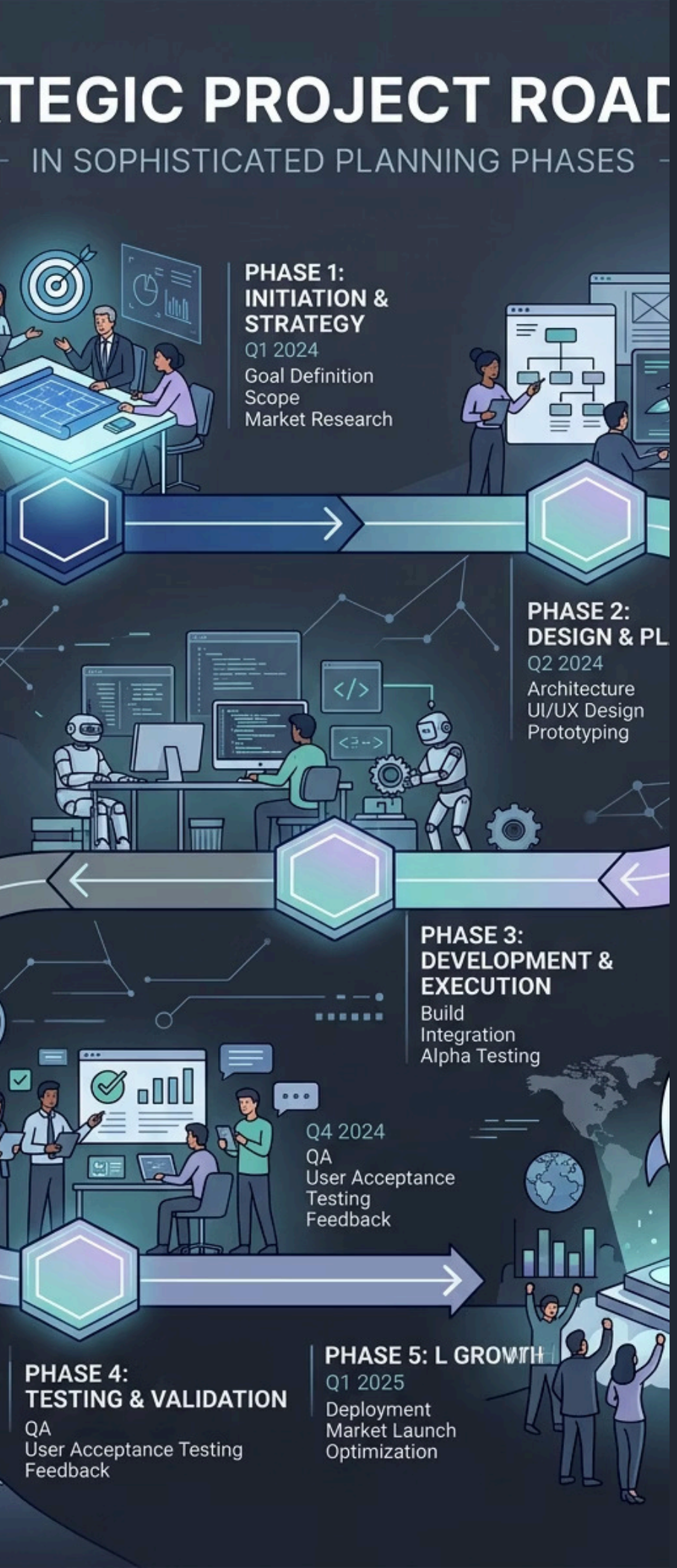
Gücləndirilmiş Nəzarət:

- PCI DSS və SWIFT CSP tələbləri
- Sərt şəbəkə segmentasiyası və VLAN yoxlamaları
- Continuous compliance monitoring
- Gücləndirilmiş logging və real-time alerting
- Agent-based endpoint visibility

Target Segment: Yüksək compliance tələbləri olan maliyyə müəssisələri

Biznes Dəyəri: Fərqləndirilmiş paketlər dəqiq market segmentasiyası və qiymət optimallaşdırması təmin edir

Made with GAMMA



12-Aylıq Roadmap: Mərhələli Hədəflər

01

Phase 1: Stabilizasiya və Daxili Deploy

Q1 - DMZ/internal server deployment, reverse proxy konfiqurasiyası, RBAC genişləndirməsi, audit log və backup/DR planı

02

Phase 2: Asset Discovery və Şəbəkə Telemetriyası

Q2 - LAN/Wi-Fi asset inventory, network device autodiscovery, 802.1X/NAC uyğunluq yoxlaması, switch/router konfiq drift detection

03

Phase 3: Policy Engine və Standart Profillər

Q3 - ISO 27001, PCI DSS, SOC 2 compliance profilləri, risk acceptance workflow, exception management, remediation SLA

04

Phase 4: Continuous Compliance və SIEM/SOC Inteqrasiyası

Q4 - Real-time monitoring, SIEM/SOC connector API, continuous control monitoring, automated alerting, governance cadence

Icraçı Nəticə: Hər mərhələ 30-45 gün ərzində çatdırıla bilər və əvvəlki mərhələlərin nəticələrini əsas götürür

Made with GAMMA

İdarəetmə Qərarı: Növbəti Addımlar

Təsdiqlənməli Hədəflər

- Daxili server deployment (Q1)
- İki yol xəritəsinin paket strukturu
- 12-aylıq roadmap timeline
- Phase 1 resurs planı və büdcə

Resurs Tələbləri

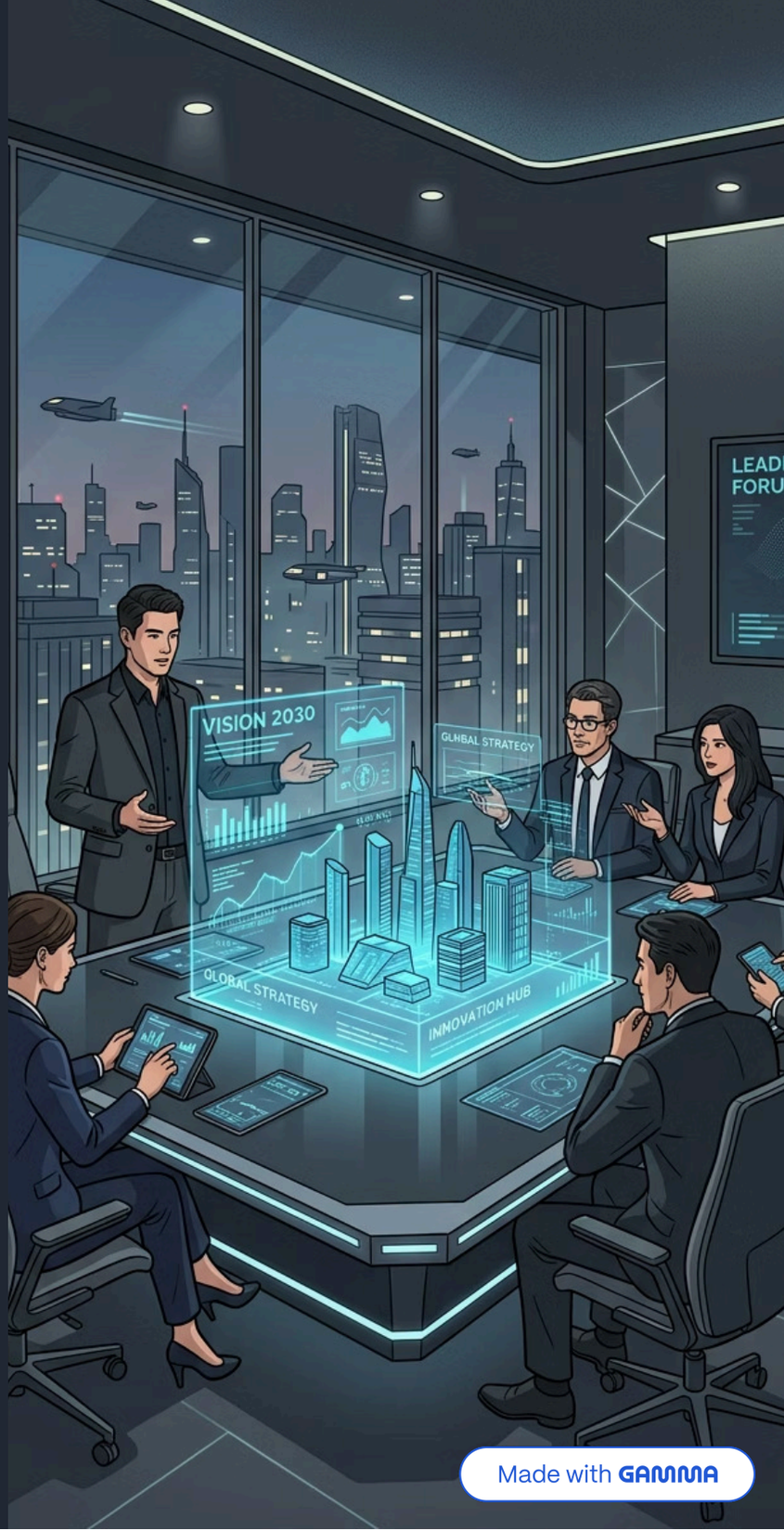
Komanda: 2 backend developer, 1 devops engineer, 1 QA tester

İnfrastruktur: Internal server (16GB RAM, 4 CPU), DMZ reverse proxy, TLS certificate

Büdcə: Development, deployment və test xərcləri

30	4	99%
Gün	Komanda	Uyğunluq
Phase 1 deployment	Full-time resurs	ISO 27001/SOC 2

Icraçı Nəticə: Q1 sonunda daxili LAN/Wi-Fi skaninq qabiliyyətinin aktivləşdirilməsi ilə risk nəzarət kontinuumunun qurulması təklif olunur



Made with GAMMA